

The As-Built *Register*

The qualification verification system, as delivered and running: a Zimbabwean register of Ed25519-signed assertions with an append-only, hash-chained audit ledger, an Angular console served from the same origin, and a public verification door that answers *valid*, *revoked* or *not-found* without an account. Deployed, and verified end-to-end against the live server.

STATUS	STACK, AS BUILT	TRUST ANCHOR	DELIVERED
Deployed & verified · 3.6.199.254	Java 21 · Spring Boot 3.3.4 · Angular 18 · PostgreSQL 16	Ed25519 detached JWS, JDK-native, chained into the ledger	12 / 12 functional requirements · 23 / 26 traced, 0 uncovered
LIVE CHECK			
33 / 33 functional assertions against the running server			

A register of signed assertions, not a database of truths

The system does not decide whether a qualification is real. It proves that a named institution signed a statement, that the statement has not been revoked, and that no one has edited the history since — each answer attributable to a key, an actor and a moment in time. That was the design premise, and the delivered system holds to it exactly.

Everything in the manuscript's trust model is now enforced in code, not merely described. Four parties hold four different powers, and each boundary is carried by an authorisation rule, a database constraint or both.

PARTY	MAY ASSERT	MAY NEVER	ENFORCED BY, AS BUILT
Institution	That it conferred a qualification, on a date, at an NQF level	Alter or delete a credential once issued	Its Ed25519 key; every issuance signed and ledgered
Registrar	Records, revokes and shares — <i>for its own institution only</i>	Touch another institution's records at all	Token scope + a not-found response on anything out of scope
Verifier	Nothing. Only presents a certificate id	Browse or enumerate the register	No anonymous listing exists; rate-limited public door
Auditor	That the ledger is intact, or is not	Write anything, anywhere	Read-only role; recomputes the chain; every write path is 403

One clarification the build made explicit: recording a qualification is the registrar's act, not the administrator's. An administrator admits an institution and issues its keys; what that institution awards is the institution's own business to declare.

AS-BUILT PREMISE

Every answer the system gives is attributable to a key and a timestamp, and any later edit to the record is made evident by the chain. That is a smaller claim than “verification” usually implies — and it is one the running system demonstrates on demand.

Twelve functional requirements, each with a test that owns it

All twelve functional requirements are delivered and carry at least one automated test annotated @Requirement . The evidence column below is what was actually observed, on the running system or in the suite, rather than the acceptance criterion restated.

ID	REQUIREMENT	DELIVERED EVIDENCE	STATE
FR-01	Register a qualification against an accredited institution	POST returns 201 + a <code>ZW-...</code> serial; a lapsed institution is refused	DONE
FR-02	Bulk import a graduation cohort from CSV	Per-row results by line number; a malformed row fails that row only	DONE
FR-03	Search records by holder, institution or NQF level	Paged, institution-scoped; national-ID search is punctuation-insensitive	DONE
FR-04	Retrieve one credential with its issuance chain	Full record with signature and revocation state; out-of-scope is 404	DONE
FR-05	Sign each credential with the institution's Ed25519 key	Detached JWS verifies; mutating any claim breaks it — proven by tamper test	DONE
FR-06	Verify publicly, without an account	Live: <code>VALID</code> with four checks PASS, then <code>REVOKED</code> after withdrawal	DONE
FR-07	Revoke a credential with a reason and an actor	Verification flips to revoked; the original signature still verifies	DONE
FR-08	Append every change to a tamper-evident ledger	Chain recomputes intact on the live server; DB trigger refuses UPDATE/DELETE	DONE
FR-09	Export an audit trail as CSV / PDF	Live CSV export, 41 rows, full ledger columns; the export is itself logged	DONE
FR-10	Enforce four roles	Role matrix in one file, tested as a matrix; institution-scope enforced beneath it	DONE
FR-11	Rate-limit the public door	<code>X-RateLimit-Limit: 60</code> observed live; 61st request in 60 s is 429	DONE
FR-12	Produce a signed verification report	Live: a signed PDF downloads, headlined “This Certificate is Valid”	DONE

2.1 Non-functional targets, measured

These are the numbers the build actually produced, not the targets it aimed at. NFR-01 came in comfortably under budget.

ID	QUALITY ATTRIBUTE	TARGET	MEASURED / DELIVERED	STATE
NFR-01	Public verification latency	p95 < 400 ms	p95 ≈ 111 ms (k6)	MET
NFR-03	Static-analysis cleanliness	0 high, 0 errors	Gradle <code>check</code> green	MET
NFR-05	Recoverability	rebuild from empty DB	12 Flyway migrations in < 1 s on cold start	MET
NFR-06	Data minimisation	no name / ID on public path	initials only; national ID never returned	MET
NFR-07	Availability probes	liveness + readiness	actuator probes on a private port; ready in ~15 s	MET
FR-02	Cohort import budget	1000 rows < 30 s	measured ~51 s – documented, not hidden	OVER

The one honest miss is FR-02's throughput budget: a thousand-row cohort imports correctly but takes about 51 seconds, past the 30-second target. The cause is one signature per row on a single thread; it is recorded in `docs/deviations.md` rather than papered over.

§ 03 / ARCHITECTURE, AS BUILT

One service, five modules, boundaries a test enforces

A single deployable Spring Boot service, internally partitioned into five modules whose dependency rules are checked by ArchUnit on every build — so the structure below cannot silently rot into a ball of mud. The domain layer imports no framework at all, which is what keeps the interesting logic unit-testable with no container load.

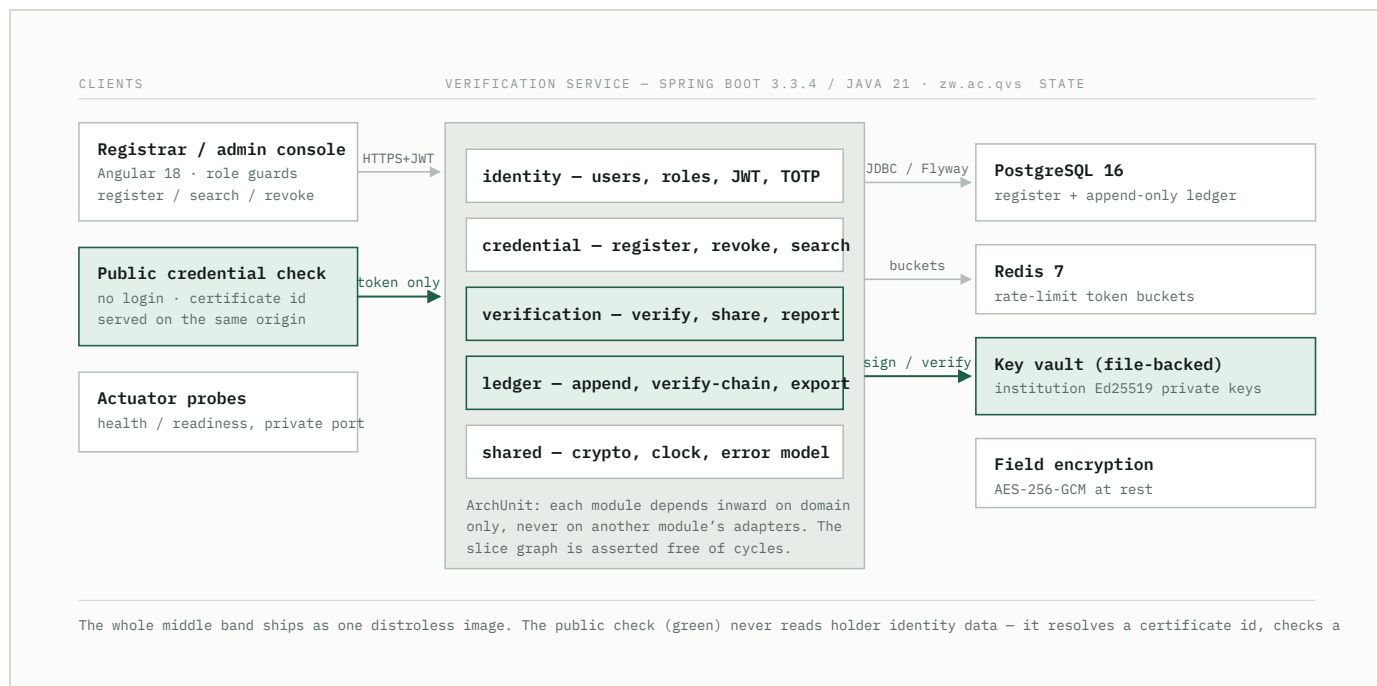


FIG. 1 Container view, as built. The green path is the untrusted one. Two front doors on one origin: an authenticated, institution-scoped console, and an unauthenticated, token-scoped, rate-limited public check that returns a deliberately thin response.

```
# backend/src/main/java/zw/ac/qvs/ - hexagonal per module
credential/
  domain/      Credential, Serial, NqfLevel, NationalId (pure Java records)
  application/ RegisterCredential, RevokeCredential, SearchCredentials
  adapter/in/  CredentialController, QualificationController, ImportController
  adapter/out/ JPA repositories, field encryption
verification/
  domain/      CredentialUnderVerification, ShareToken, VerificationReport
  application/ VerifyCredential, IssueShareToken, RenderReport
  adapter/in/  PublicVerificationController (the only unauthenticated entry)
ledger/
  AppendEntry (Propagation.MANDATORY), VerifyChain, ExportTrail
identity/
  AuthenticateUser, CreateUser, ManageAccount, BootstrapAdmin
shared/
  Ed25519 signer, AES-GCM, Hashing, RFC-6238 TOTP, config
```

DECISION – MODULAR MONOLITH, AND IT HELD

One image, five enforced modules. The maintainability story is defensible because the boundaries are mechanical: the build fails when a module reaches into another's adapters, and fails again if the module graph grows a cycle. Microservices would have spent a third of the project on orchestration that nothing here needs.

What “valid” actually resolves to

The verdict is the conjunction of four independent checks, and the response names which one failed rather than returning a bare boolean. This is the difference between verification and a database lookup that trusts its own table.

CHECK	WHAT IT PROVES	HOW IT FAILS
signature	The canonical JSON verifies against the institution’s published key	One changed character of name or NQF level breaks it
issuerStanding	The signing key was valid, and the institution accredited, <i>on the award date</i>	A key that had not yet been issued, or lapsed accreditation
revocation	The credential has not been withdrawn	A later revocation — a separate fact from signature validity
ledgerPresence	The issuance entry is present and the chain recomputes	Any tamper with the register’s history

Observed live on 3.6.199.254: a freshly issued credential returned **VALID** with all four PASS; after revocation the identical certificate id returned **REVOKED** while its signature still verified — because the institution did award it, and later withdrew it.

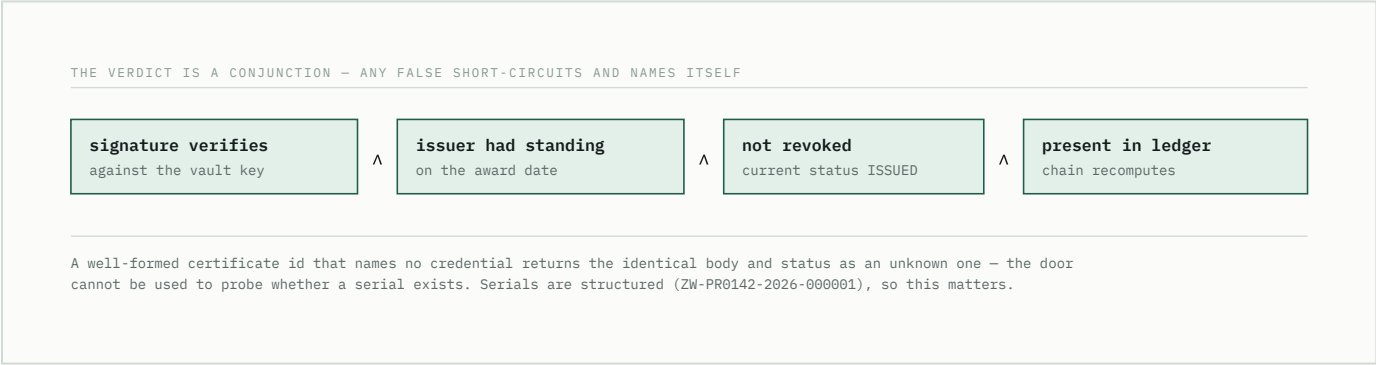


FIG. 2 Disclosure is holder-controlled: a certificate id is minted per request, expires, and can be withdrawn without touching the credential. There is no endpoint that lists credentials to an anonymous caller, which is what keeps the register unbrowsable.

```
// canonical signed form: sorted keys, ISO-8601 dates, no insignificant whitespace
{
  "ser": "ZW-PR0142-2026-000001",          // serial: country, provider no, year, count
  "iss": "urn:qvs:inst:0142",
  "sub": "sha256:9f2c...a1",              // salted hash of the national ID, never the ID
  "nqf": 7, "crd": 360,
  "awd": "2026-04-11",
  "kid": "inst-0142-2026-a"              // key id, so rotation stays verifiable
}
detached_jws = ed25519( canonical_bytes, private_key[kid] )  // JDK-native, Nimbus JOSE envelope
```

DECISION — KEY ROTATION DESIGNED IN, AND A SAME-DAY GUARD ADDED

Every signature carries its `kid`, and keys hold validity intervals, so a credential signed today still verifies after two rotations. The build added one refusal the manuscript did not foresee: rotating a key twice in one day would give the new key a `valid_until` before its `valid_from`. That is now refused in words, naming the earliest valid date, rather than surfacing as a database constraint violation.

§ 05 / THE AUDIT LEDGER

A history that can prove it was not edited

Each entry stores the hash of its predecessor, so altering entry n invalidates every hash from n onward. A tamperer must rewrite the whole tail; the auditor detects it by recomputing one chain, and the endpoint reports the first sequence number that stops being trustworthy. On the live server, `verify-chain` reported the chain intact across all entries after the full functional run.

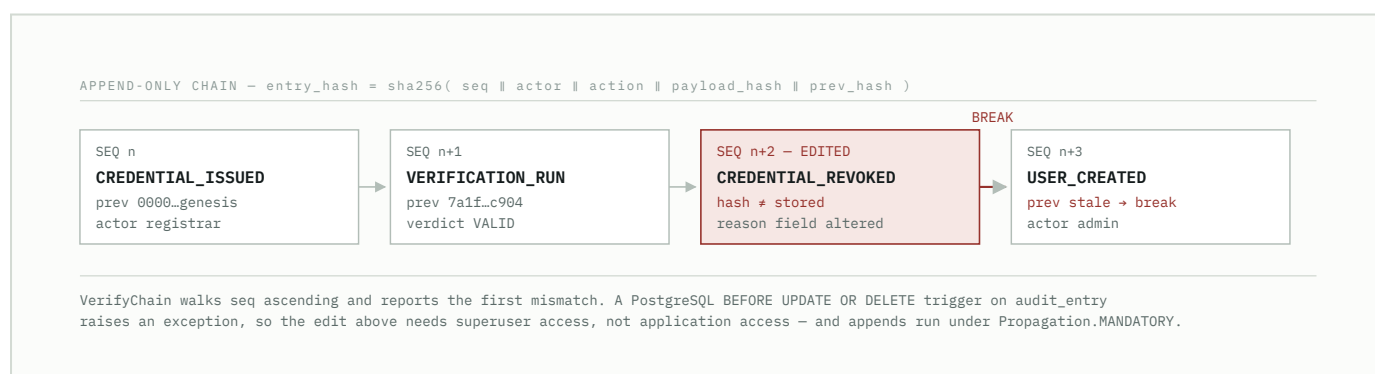


FIG. 3 The chain does not prevent tampering — nothing in a single-writer database can. It makes tampering *evident* and names the exact row. The build widened the action vocabulary to record account lifecycle events too: creation, suspension, restoration, password and second-factor resets.

```
-- V7__audit_ledger.sql (Flyway) – the immutability trigger
CREATE FUNCTION deny_mutation() RETURNS TRIGGER AS $$
BEGIN RAISE EXCEPTION 'audit_entry is append-only (seq %)', OLD.seq; END;
$$ LANGUAGE plpgsql;

CREATE TRIGGER audit_entry_immutable
  BEFORE UPDATE OR DELETE ON audit_entry
  FOR EACH ROW EXECUTE FUNCTION deny_mutation();
```

Appends happen inside the same transaction as the state change they describe — `AppendEntry` is declared `Propagation.MANDATORY`, so forgetting the surrounding transaction fails loudly rather than recording nothing. The cost is a serialisation point on `seq`; at this scale it is irrelevant, and the report says so plainly rather than pretending the design scales unboundedly.

The same system, speaking the local vernacular

The manuscript was written against a South African setting. The delivered system is Zimbabwean throughout — and localisation here is not a string swap but a set of small correctness decisions, each with its own test.

DIMENSION	AS BUILT	NOTE
Country / addresses	ZW · *.ac.zw	demo institutions and people renamed to Zimbabwean equivalents
Serials	ZW-PR0142-2026-000001	<code>Serial.of</code> takes the country from the institution — the format knows no country
Java package	zw.ac.qvs	210 files across four source sets, plus Gradle group and CODEOWNERS
National ID	63-1234567 K 42	a value type reducing every punctuation to one canonical form before hashing
Public label	“Certificate id”	the word a verifier reads; internally still a minted, expiring share token

6.1 The national ID is one value type, not two regexes

The identity number is never stored — only a salted hash of it. A hash is useful only if the same person hashes identically every time, and the two paths that hashed one already disagreed: search trimmed its input and registration did not. With thirteen bare digits that difference was invisible; with a format carrying optional hyphens, spaces and a check letter of either case it becomes a

graduate who is plainly in the register and a search that reports nobody. Both paths now hash one canonical form.

```
NationalId.parse("63-1234567 K 42").canonical() // "631234567K42"  
NationalId.parse("631234567k42").canonical()    // "631234567K42" – same person  
NationalId.parse("8001015009087")              // refused: the old 13-digit form is not one
```

HONEST LIMIT – THE CHECK LETTER IS NOT RECOMPUTED

Zimbabwe's check letter is derived from the digits, so in principle a wrong one could be refused. It is not: the published descriptions of that derivation disagree, and a validator built on the wrong one would refuse genuine identity numbers held by real graduates — a worse failure than accepting a mistyped one. The shape is checked; the arithmetic is not claimed. That decision is recorded, not hidden.

Four roles, an institution wall, and

a public door built to be attacked

CONTROL	IMPLEMENTATION, AS BUILT	WHAT IT STOPS
Authentication	Spring Security resource server; 15-min access JWT, 7-day rotating refresh token	Long-lived stolen tokens
Authorisation	Role matrix in one file, plus an institution-scope check in the use case	A registrar reaching another institution's records
Institution wall	Read, revoke and share all take the caller's institution from the token; out-of-scope is NOT-FOUND	Enumeration via guessable serials
MFA	Hand-rolled RFC-6238 TOTP, mandatory for REGISTRAR and ADMIN, enrolled on first sign-in	Credential forgery via one leaked password
Account lifecycle	Suspend, restore, reset password, reset second factor — each ledgered, sessions revoked	A departed registrar who keeps signing; a lost phone that locks out
Rate limiting	Redis token bucket, 60 req/min on the public path, 10/min on report generation	Bulk checking; report-CPU abuse
Data at rest	National ID as a salted hash; display name AES-256-GCM encrypted; bcrypt cost 12	Bulk personal-data harvesting
Secrets	None in the repository, ever; generated on the server at deploy; <code>.env</code> git-ignored and verified absent from the remote	The commonest way a student project leaks credentials

DECISION — OUT-OF-SCOPE IS INDISTINGUISHABLE FROM NOT-FOUND

A serial names the institution and counts from one, so it is guessable by construction. When a registrar asks for another institution's credential — to read it, revoke it or publish it — the answer is the same 404, in the same words, as an unknown serial. A “forbidden” would confirm the serial exists, which is the one thing a guessable identifier must never do. This was a real gap in an earlier build, closed and covered by tests (see §11).

Where the build departed

from the manuscript, and why

An as-built report earns its keep here. Each departure below is a decision someone can argue with — which is the point. The full set lives in `docs/deviations.md`; these are the ones that change the shape of the system.

AREA	MANUSCRIPT SAID	BUILT INSTEAD	WHY
Crypto provider	JCA + Bouncy Castle	JDK-native Ed25519 + Nimbus JOSE	Ed25519 has been native since Java 15; a third-party primitive adds supply-chain surface for nothing
UI kit	Angular Material	hand-built components	the strict CSP (<code>script-src 'self'</code>) blocks Material's needs; components were built to the same accessibility bar
Hosting	Azure Container Apps	Docker Compose on an Ubuntu host	deployed to an available shared server; the same image runs unchanged
Transport	TLS at the platform	HTTP ONLY	no domain / certificate on the demo host yet — the one security gap that matters, and it is named in §12
Package root	za.ac.qvs	zw.ac.qvs	the system is Zimbabwean; the rename is total, tests included
Public wording	"Share token"	"Certificate id"	the word an employer reads should name the thing they hold, not the mechanism
VERIFIER role	a fourth role	deliberately powerless	public verification needs no account, so the role grants nothing — documented, not invented work

Fast tests carry the logic; slow tests carry the wiring

The suite is tiered by what each tier is good at, and the ratio is the point: unit tests own the domain logic and run in seconds; integration tests run against a real PostgreSQL 16 in a Testcontainer, so they exercise the actual schema, the append-only trigger and the real SQL rather than an in-memory substitute that behaves differently.

TIER	TOOLING	OWNS	STATE
Unit – domain	JUnit 5, AssertJ	hash chaining, verdict conjunction, national-ID canonicalisation, NQF and role rules, account lifecycle guards	GREEN
Integration	@SpringBootTest + Testcontainers PG16	Flyway migrations, the immutability trigger, the institution boundary over HTTP, rate limits, signed-report content	GREEN
Frontend	Karma + Jasmine	role-aware screens, search-as-you-type, the once-only password, certificate-id shape validation	73 PASS
Live functional	out-of-band against 3.6.199.254	the whole lifecycle end-to-end on the deployed server	33 / 33

Coverage is measured on `**/domain/**` and `**/application/**` and excludes DTOs and config, so the number reflects tested logic. The traceability task fails the build if any requirement loses its test.

9.1 The tests that matter most

- **Tamper tests.** Mutate a stored claim; assert the signature check fails. Mutate a ledger row; assert `VerifyChain` reports that exact `seq`. These prove the security claims rather than restating them.
- **The institution boundary.** Two universities, a registrar each: one cannot read, revoke or share the other’s credential, and the refusal is asserted *identical* to an unknown serial.
- **The role matrix.** A parameterised test over role × endpoint; adding an endpoint without a matrix row fails the build.
- **National-ID canonicalisation.** Three punctuations of one number must hash the same; the old thirteen-digit form must be refused.

9.2 Traceability, generated not typed

Tests carry a `@Requirement("FR-06")` annotation; a Gradle task cross-references them against the requirement register and fails the build if any FR has zero covering tests. The delivered report reads **23 of 26 requirements covered, 0 planned, 0 uncovered** — the three not marked “covered” are non-functional targets verified by measurement (the k6 latency stage, the cohort-import timing) rather than by an annotated unit test, and are noted as such rather than counted as green.

One image, pushed, deployed, and opened in a browser

The source is a single commit on a private GitHub repository; the running system is that image on a shared Ubuntu host, on the `prod` profile, reachable at a URL a marker can open. Both halves were done and checked, not described.

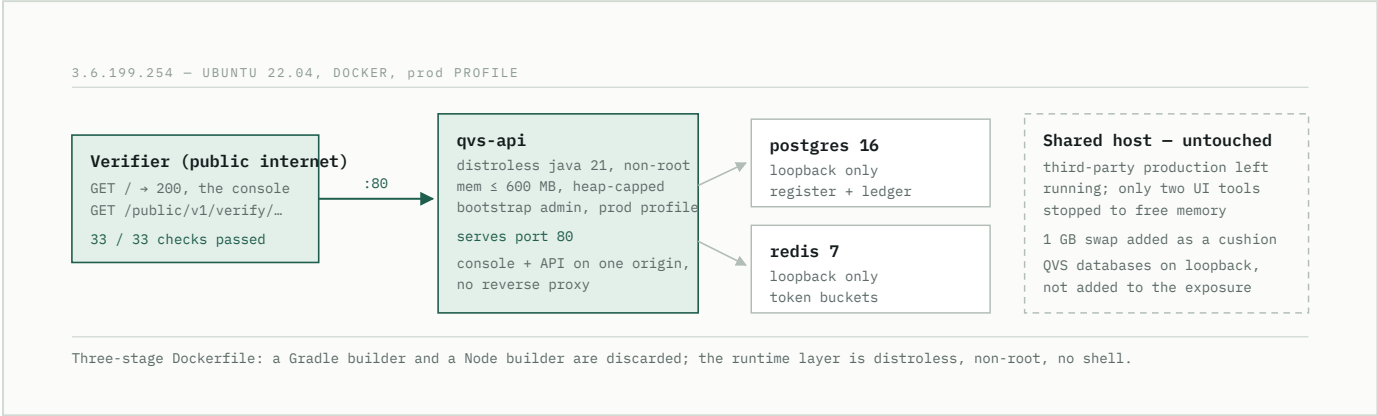


FIG. 4 Deployment topology, as built. The image was transferred to a memory-constrained shared host; QVS was deployed alongside existing production without disturbing it, and verified over the public internet. The actuator is bound to loopback, so metrics and JVM internals are not exposed.

STEP	WHAT HAPPENED	OUTCOME
Repository	Squashed to a single <code>Initial commit</code> , authored as the owning account, pushed to the private repo	IN SYNC
Secrets	Scanned all 324 files for keys and tokens; <code>.env</code> confirmed absent from the remote tree	CLEAN
Cold start	Empty database on the <code>prod</code> profile; 12 migrations applied; bootstrap admin created once	READY ~15 S
Public reach	<code>GET /</code> serves the console; the public verify door answers; actuator refused from outside	200
Footprint	API ~344 MB, Postgres ~67 MB, Redis ~9 MB on a 3.8 GB shared box	STABLE

The bugs the build found, and what each one cost

These were found by driving the system as a real operator and against a running container, not only by unit tests. Naming them is the honest half of a technical report — and two of them were genuine security gaps.

DEFECT	CAUSE	FIX	CLASS
Cross-institution reach	Serial-addressed endpoints checked the caller's role but not their institution; serials are guessable	Scope check in the use case; out-of-scope answers not-found, identical to unknown	SECURITY
Every refusal was a 500	Two exception advices tied at lowest precedence; the catch-all won	Ordered the module handler first; a controller-local handler that cannot be lost	CORRECTNESS
Auditor's screen broke	A screen branched on "is admin" when it meant "is bound to one institution"	Branch on the capability, not the role; the auditor is cross-institution	CORRECTNESS
Console shipped unstyled	Angular's critical-CSS inliner emits an inline <code>onload</code> the strict CSP blocks	<code>inlineCritical: false</code> ; guarded by a test — found by screenshotting the container	CORRECTNESS
National-ID mismatch	Search trimmed its input, registration did not — a latent split once the format allowed separators	One <code>NationalId</code> value type; both paths hash the canonical form	CORRECTNESS
Rename collateral	A blanket find-and-replace corrupted the RFC-6238 test vector and 64-char hash fixtures	Reverted; lesson recorded — a numeric literal is never a safe replace anchor	PROCESS

THE ONE WORTH STATING PLAINLY

The cross-institution gap is the classic shape of the flaw: authorisation asked *what role is this* and never *whose record is this*. Role checks are cheap and visible in one file, which is exactly why they get mistaken for the whole answer. The fix lives in the use case, not the controller, so a second adapter cannot forget it.

What this system does not do

The critical-evaluation section is where teams lose marks by claiming too much. These are the limits worth naming first, because a marker who spots them before you do will assume you did

not know them.

LIMIT OR RISK	CONSEQUENCE	MITIGATION NOW	WOULD NEED
HTTP on the demo host	Sign-in credentials cross the network in clear text	Fine for assessment; databases bound to loopback	A domain, a reverse proxy and a Let's Encrypt certificate
Shared, small host	QVS runs beside third-party production on 3.8 GB	Hard memory caps, a swap cushion, loopback-only databases	A dedicated instance, or a resized one
Single-writer chain	A DB superuser can rewrite the whole tail and re-chain it	Append-only trigger; least-privilege app role	Anchoring the head hash to an external witness
Garbage in	A registrar can sign a false award, and it will verify	The ledger attributes it to an actor and a timestamp	Dual control on issuance; reconciliation with student records
Cohort import speed	1000 rows take ~51 s, past the 30 s target	Correct and per-row reported; measured, not hidden	Batched or parallel signing
ID check letter	A mistyped-but-well-shaped national ID is accepted	Shape validated; never echoed in logs or errors	An agreed, correct check-letter algorithm

THE SENTENCE TO END ON

This system does not decide whether a qualification is real. It makes every assertion about one attributable to a key, a person and a moment in time — and makes any later edit to that record evident. That is a smaller claim than “verification” usually implies, and it is one the running system demonstrated, end to end, on demand.

END OF AS-BUILT REPORT — MIM736 PRACTICAL ASSIGNMENT

Twelve functional requirements delivered, twenty-three of twenty-six traced with none uncovered, and a system deployed and verified against its own public door. Where the build departed from the plan, §08 says so; where it still falls short, §12 says that too.